



## Raport dla klienta

Badanie bezpieczeństwa sieci od środka

**5**

Wykryte urządzenia

**10**

Otwarte porty

**10**

Ustalenia wymagające działania

**5**

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 14:03:26 UTC

# 1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie wykazało, że sieć wymaga działań naprawczych. Z pięciu wykrytych urządzeń cztery odpowiedziały na sprawdzenie, a łącznie znaleziono dziesięć otwartych punktów dostępu do usług. Jedno ustalenie ma wagę krytyczną, trzy wysoką, a sześć średnią — nie ma podstaw, by którykolwiek z tych problemów uznać za błahy.

Najpoważniejszy problem dotyczy serwera 192.0.2.30, na którym stwierdzono krytyczną podatność w sposobie szyfrowania połączeń oraz osobną podatność pozwalającą na czasowe odcięcie tego serwera od sieci. Oba te fakty mogą bezpośrednio wpłynąć na dostępność i poufność danych firmy, dlatego zalecam potraktować je jako najpilniejsze do usunięcia. Dodatkowo część testów nie odbyła się, więc obraz sieci nie jest pełny — nie oznacza to jednak, że w niezbadanych obszarach jest bezpiecznie.

## 2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

1

Krytyczne

3

Wysokie

6

Średnie

0

Informacyjne

| WAGA      | GDZIE                                          | USTALENIE                                                                                                                                                                                                      |
|-----------|------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Krytyczne | 192.0.2.30<br>ssl-poodle · port 8443           | SSL POODLE information leak<br>CVE-2014-3566                                                                                                                                                                   |
| Wysokie   | 192.0.2.30<br>http-slowloris-check · port 8443 | Slowloris DOS attack<br>CVE-2007-6750                                                                                                                                                                          |
| Wysokie   | 192.0.2.20<br>23/TCP                           | Telnet dostępny w sieci<br>Protokół przesyła hasła otwartym tekstem.                                                                                                                                           |
| Wysokie   | cała sieć                                      | Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.                                                                                                                                     |
| Średnie   | 192.0.2.20<br>port 80                          | Panel kamery dostępny po nieszyfrowanym HTTP<br>Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.                                                                                                          |
| Średnie   | 192.0.2.1<br>port 53                           | Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1)<br>CVE-2021-3448, CVE-2020-25681, CVE-2020-25684<br>Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany. |
| Średnie   | 192.0.2.10<br>445/TCP                          | Udostępnianie plików SMB dostępny w sieci<br>Dostęp do plików i klasyczny cel ataków w sieci lokalnej.                                                                                                         |
| Średnie   | 192.0.2.30<br>3306/TCP                         | Baza danych MySQL dostępny w sieci<br>Baza danych nasłuchująca w sieci.                                                                                                                                        |
| Średnie   | 192.0.2.30<br>502/TCP                          | Modbus dostępny w sieci                                                                                                                                                                                        |
| Średnie   | cała sieć                                      | Porty przepuszczane na zewnątrz: 23, 445, 3389                                                                                                                                                                 |

### Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

Ustalenie krytyczne dotyczy serwera 192.0.2.30 i sposobu nawiązywania szyfrowanego połączenia na porcie 8443. Mechanizm tej wady pozwala osobie postronnej odszyfrować fragmenty przesyłanych danych, co w praktyce grozi wyciekiem informacji, które powinny pozostać poufne.

Wśród ustaleń o wadze wysokiej pierwsze dotyczy także serwera 192.0.2.30 — jego usługa sieciowa jest podatna na atak polegający na stopniowym zawieszaniu połączeń, co może doprowadzić do czasowej niedostępności serwisu dla pracowników i klientów. Drugie to otwarty dostęp przez Telnet na urządzeniu 192.0.2.20; ten sposób łączenia przesyła hasła jawnym tekstem, więc ktoś w sieci mógłby je przechwycić i przejąć kontrolę nad urządzeniem. Trzecie ustalenie wysokie to brak zabezpieczenia przed przekierowywaniem ruchu w sieci lokalnej — bez tej blokady ktoś podłączony do sieci mógłby podsłuchiwać przesyłane dane i podszywać się pod inne urządzenia.

Ustalenia średnie obejmują podatności znane z numeru wersji oprogramowania routera 192.0.2.1, nieszyfrowany panel kamery na 192.0.2.20, otwarte udostępnianie plików na 192.0.2.10, dostępną bazę danych i łącze przemysłowe na 192.0.2.30 oraz przepuszczanie na zewnątrz ruchu z portów 23, 445 i 3389. Trzeba też pamiętać, że pięć obszarów nie zostało w ogóle sprawdzonych — na przykład skan urządzenia 192.0.2.40 zakończył się niepowodzeniem, a testy sieci bezprzewodowej i katalogu użytkowników nie odbyły się. Tych obszarów nie można obecnie ocenić jako bezpiecznych.

### 3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

| ADRES      | ADRES SPRZĘTOWY   | PRODUCENT I MODEL                          | STAN                                                |
|------------|-------------------|--------------------------------------------|-----------------------------------------------------|
| 192.0.2.1  | 02:00:5e:00:53:01 | Acme Networks GW-200<br>Linux 4.x (router) | 3 otwarte porty                                     |
| 192.0.2.10 | 02:00:5e:00:53:0a | NorthStore NAS-4B<br>Linux (NAS)           | 2 otwarte porty                                     |
| 192.0.2.20 | 02:00:5e:00:53:14 | Visinet IP-Cam 3<br>Embedded Linux         | 2 otwarte porty                                     |
| 192.0.2.30 | 02:00:5e:00:53:1e | Generic Server Co.<br>CentOS 7             | 3 otwarte porty                                     |
| 192.0.2.40 | —                 | nieznany                                   | skanowanie nieudane<br>test przekroczył limit czasu |

Wykrytych urządzeń: **5**, odpowiedziało na skanowanie portów: **4**.

W sieci wykryto pięć urządzeń, z czego cztery odpowiedziały na sprawdzenie dostępnych usług. Są to router 192.0.2.1, urządzenie do przechowywania danych 192.0.2.10, kamera 192.0.2.20 oraz serwer 192.0.2.30; wszystkie cztery mają co najmniej jeden otwarty punkt dostępu. Piąte urządzenie, 192.0.2.40, nie odpowiedziało na skanowanie — test przekroczył limit czasu, więc nie wiemy, jakie usługi udostępnia.

To, że urządzenia odpowiadają i wystawiają usługi, jest normalne w działającej sieci, ale każdy otwarty punkt dostępu to potencjalne wejście dla kogoś niepowołanego. Szczególną uwagę zwraca serwer 192.0.2.30, który koncentruje najpoważniejsze ustalenia z całego badania.

## 4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

| URZĄDZENIE | PORT     | USŁUGA       | WERSJA ROZPOZNANA PRZEZ SONDĘ |
|------------|----------|--------------|-------------------------------|
| 192.0.2.1  | 53/TCP   | domain       | dnsmasq 2.80                  |
| 192.0.2.1  | 80/TCP   | http         | lighttpd 1.4.59               |
| 192.0.2.1  | 443/TCP  | https        | lighttpd 1.4.59               |
| 192.0.2.10 | 445/TCP  | microsoft-ds | Samba smbd 4.15.13            |
| 192.0.2.10 | 5000/TCP | http         | Synology DSM httpd            |
| 192.0.2.20 | 23/TCP   | telnet       | nie ustalono                  |
| 192.0.2.20 | 554/TCP  | rtsp         | nie ustalono                  |
| 192.0.2.30 | 22/TCP   | ssh          | OpenSSH 7.4                   |
| 192.0.2.30 | 3306/TCP | mysql        | MySQL 5.7.38                  |
| 192.0.2.30 | 8443/TCP | https        | nie ustalono                  |

Otwartych portów łącznie: 10, na 4 urządzeniach.

(powtórzenie pominięte — patrz sekcja powyżej)

## 5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

| URZĄDZENIE | TEST                 | USTALENIE                                                                                 |
|------------|----------------------|-------------------------------------------------------------------------------------------|
| 192.0.2.30 | ssl-poodle           | VULNERABLE:<br>SSL POODLE information leak<br>State: VULNERABLE<br>IDs: CVE:CVE-2014-3566 |
| 192.0.2.30 | http-slowloris-check | VULNERABLE:<br>Slowloris DOS attack<br>State: LIKELY VULNERABLE<br>IDs: CVE:CVE-2007-6750 |

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

Uruchomione pogłębione testy dały trzy ustalenia, z czego dwa wymagają uwagi. Na serwerze 192.0.2.30 potwierdzono krytyczną podatność w sposobie szyfrowania połączeń, która umożliwia wyciek informacji, oraz wysoką podatność pozwalającą na czasowe zawieszenie usługi sieciowej. Trzeci test zakończył się wynikiem czystym, co oznacza, że w sprawdzonym zakresie niczego nie wykryto.

Oba potwierdzone problemy dotyczą tego samego serwera i tej samej usługi, dlatego naprawę warto zaplanować łącznie. Do czasu jej wdrożenia serwer 192.0.2.30 jest najbardziej narażonym elementem sieci.

## 6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

| BADANY OBSZAR                            | WYNIK                                                                                         |
|------------------------------------------|-----------------------------------------------------------------------------------------------|
| Anonimowe sesje i udziały SMB            | stan prawidłowy — nie stwierdzono podatności                                                  |
| Zatruwanie rozgłoszeń                    | brak danych<br>Sonda nie przekazała wyniku tego testu.                                        |
| Skanowanie szablonami znanych podatności | stan prawidłowy — nie stwierdzono podatności                                                  |
| Domyślne poświadczenia                   | stan prawidłowy — nie stwierdzono podatności                                                  |
| Wycieki z katalogu LDAP                  | test nie wykonał się<br>Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony. |
| Ryzyka infrastrukturalne                 | stan prawidłowy — nie stwierdzono podatności                                                  |

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

Testy dotyczące anonimowego dostępu do udziałów plików, domyślnych haseł oraz znanych wzorców podatności zakończyły się bez wykrycia problemów — w tych obszarach stan jest prawidłowy. Nie oznacza to jednak, że wszystkie zagadnienia z tej grupy zostały sprawdzone.

Test wykrywający wycieki z katalogu użytkowników nie odbył się, więc nie wiemy, czy dane użytkowników są odpowiednio chronione. Podobnie test zatruwania rozgłoszeń nie został ukończony — sonda nie przekazała wyniku — więc nie można potwierdzić, czy mechanizm przekierowywania ruchu jest zabezpieczony. Oba te obszary pozostają niezbadane.

## 7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

| URZĄDZENIE | PORT    | PROTOKÓŁ | STAN | OCENA SONDY |
|------------|---------|----------|------|-------------|
| 192.0.2.30 | 502/TCP | Modbus   | open | WARNING     |

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

W sieci znaleziono jeden punkt końcowy protokołu przemysłowego: na serwerze 192.0.2.30 działa łącze Modbus na porcie 502, które sonda oceniła jako wymagające uwagi. Protokoły przemysłowe służą do sterowania urządzeniami technicznymi i zwykle nie mają wbudowanych zabezpieczeń dostępu.

Jeśli to łącze ma faktycznie obsługiwać urządzenia technologiczne, powinno znajdować się w wydzielonej części sieci, niedostępnej dla zwykłych komputerów biurowych. Obecność takiego punktu na serwerze ogólnego przeznaczenia oznacza, że ktoś z sieci biurowej mógłby próbować wysyłać do niego polecenia sterujące.

## 8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

### Opóźnienia w sieci

|           |        |
|-----------|--------|
| Status    | ok     |
| Najniższe | 0.4 ms |
| Średnie   | 0.8 ms |
| Najwyższe | 1.9 ms |

### Kondycja DNS

|                 |           |
|-----------------|-----------|
| Status          | ok        |
| Odpytany serwer | 192.0.2.1 |
| Czas odpowiedzi | 12 ms     |

### Podatność na podsłuch (MITM)

|                                                                              |                                                                               |
|------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| Status                                                                       | ok                                                                            |
| ▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać. |                                                                               |
| Assessment                                                                   | Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować. |

### Filtrowanie ruchu wychodzącego

|                                 |                 |
|---------------------------------|-----------------|
| Status                          | ok              |
| Porty przepuszczane na zewnątrz | ▲ 23, 445, 3389 |

### Bezpieczeństwo sieci bezprzewodowej

|                                                                     |               |
|---------------------------------------------------------------------|---------------|
| Status                                                              | blocked       |
| Reason                                                              | foreign_block |
| ▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył. |               |
| Przechwycone ramki EAPOL                                            | 0             |

### Przepustowość łącza

|                   |              |
|-------------------|--------------|
| Opóźnienie (ping) | 18.4 ms      |
| Pobieranie        | 184.2 Mbit/s |
| Wysyłanie         | 41.7 Mbit/s  |

Najbardziej obciążające urządzenia

| ADRES      | PAKIETY | RUCH ŁĄCZNIE | WYSŁANE            | ODEBRANE           |
|------------|---------|--------------|--------------------|--------------------|
| 192.0.2.10 | 182340  | 136,3 MB     | 90000 pk · 76,3 MB | 92340 pk · 60,0 MB |
| 192.0.2.1  | 90120   | 17,5 MB      | 45000 pk · 8,6 MB  | 45120 pk · 9,0 MB  |

Kondycja podstawowych parametrów sieci jest dobra — opóźnienia w przesyłaniu danych są niskie, a serwer tłumaczenia nazw odpowiada poprawnie w czasie 12 milisekund. Przepustowość łącza również nie budzi zastrzeżeń, a największy ruch generuje urządzenie do przechowywania danych 192.0.2.10.

Niepokój budzą natomiast dwa elementy konfiguracji. Po pierwsze, sieć nie blokuje przekierowywania ruchu, co pozwala na jego przechwytywanie i podsłuchiwanie. Po drugie, na zewnątrz przepuszczany jest ruch z portów 23, 445 i 3389, co zwiększa powierzchnię narażoną na kontakt z internetem. Bezpieczeństwo sieci bezprzewodowej nie zostało zbadane, ponieważ nie udało się włączyć trybu nasłuchu — obszar ten pozostaje niesprawdzony.

## 9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

1. Usuń potwierdzoną podatność krytyczną na serwerze 192.0.2.30 (port 8443) — zaktualizuj lub wyłącz niebezpieczny sposób szyfrowania, aby zatrzymać wyciek informacji.
2. Zabezpiecz serwer 192.0.2.30 przed atakiem zawieszającym jego usługę sieciową — to bezpośrednie zagrożenie dla dostępności systemu.
3. Wyłącz Telnet na kamerze 192.0.2.20 i zastąp go szyfrowanym sposobem zdalnego dostępu, aby hasła nie były przesyłane jawnym tekstem.
4. Włącz na przełączniku blokadę przekierowywania ruchu, aby uniemożliwić podsłuchiwanie i podszywanie się pod urządzenia w sieci.
5. Ogranicz przepuszczanie na zewnątrz ruchu z portów 23, 445 i 3389, zamykając zbędne kanały wyjścia.
6. Zabezpiecz panel kamery 192.0.2.20 — wymuś szyfrowane połączenie i ogranicz dostęp do sieci zarządzającej.
7. Potwierdź i usuń podatności w oprogramowaniu routera 192.0.2.1 — dopasowanie wyniku z numeru wersji, więc najpierw sprawdź, czy zagrożony kod jest używany.
8. Ogranicz dostęp do udostępniania plików na 192.0.2.10 oraz do bazy danych na 192.0.2.30 — powinny być osiągalne tylko dla uprawnionych urządzeń.
9. Wydziel łącze przemysłowe Modbus na 192.0.2.30 do osobnej części sieci, niedostępnej dla komputerów biurowych.
10. Powtórz badanie urządzenia 192.0.2.40 oraz dokończ testy sieci bezprzewodowej i katalogu użytkowników, aby domknąć luki w sprawdzeniu sieci.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.